Online Resource 1 — Outside the Prompt: exact client prompts, deviations log and protocol detail

Paolo Costanzo[1*]

[1*]Independent researcher, CoDe RTD, Turin, Italy.

Corresponding author(s). E-mail(s): me@paolocostanzo.com;

Abstract

Electronic Supplementary Material for the article *Outside the Prompt: Measuring Where AI Coding Agents Trust Repositories, Tools and Connectors* (Empirical Software Engineering). Section B reproduces the exact text of the client questions discussed in the paper's RQ2 and RQ3 sections; Section D lists every deviation from preregistration v2 (D1–D56); both were appendices of earlier versions of the paper and are reproduced here unchanged. Section E holds protocol detail moved from the paper's body. Section, table and appendix numbers without a letter prefix (e.g. Section 7, Table 1) refer to the paper. The deviations log and the client captures it reproduces are in the artifact archive.

Appendix B Exact prompts shown by each client

This appendix reproduces the text that each client put on screen at the questions discussed in Sections 6 and 7, with the options in the order shown and the option that was pre-selected. Terminal text is copied from the saved screen captures (plain text from the terminal multiplexer), editor text from the screenshots. Conventions: box-drawing characters and blank lines are removed; the terminal wrapped lines at 160 columns, and they are re-flowed here; the selection glyph of each client (`U+276F`, `U+203A`, `U+25CF` or `U+25B6`) is written `>`; `[...]` marks text left out here; *[collapsed]* marks content that the client itself hides behind a key or a link, so that it is absent from the capture. Each capture is given with the SHA-256 recorded in the lab manifest when the capture was made. Where repetitions produced byte-identical captures, the manifest lists the same hash for each.

B.1 Opening an untrusted repository (RQ2)

Claude Code 2.1.283 (re-checked on 2.1.295).

First prompt, on opening the folder; pre-selected: *No, exit*.

```
Accessing workspace:
/home/lab/q5-repo
Quick safety check: Is this a project you created or one you trust? (Like
your own code, a well-known open source project, or work from your team). If
not, take a moment to review what's in this folder first.
Claude Code'll be able to read, edit, and execute files here.
Security guide
> No, exit
  Yes, I trust this folder
Enter to confirm · Esc to cancel
```

Second prompt, after *Yes, I trust this folder*; pre-selected: the third option.

```
New MCP server found in this project: q5-canary
MCP servers may execute code or access system resources. All tool calls
require approval. Learn more in the MCP documentation.
  Use this MCP server
  Use this and all future MCP servers in this project
> Continue without using this MCP server
Enter to confirm · Esc to cancel
```

First: evidence/q5-run/20261009-194314/captures/claude-code__untrusted__r1__prompt.txt
`102ac6526c97939e12a6b0348c50f57e664b51f46e948a7ff582341ae69ac983`
Second:
evidence/q5-run/20261009-194314/captures/claude-code__after-decision__r1__prompt.txt
`37986f113af152c8382d8390c54662eb4a68d72878427b5abbb8e8e1dbada36c`
On 2.1.295 (evidence/q5-run/recheck-20261009/matrix-current-versions/captures/) the manifest records the same two hashes for the corresponding captures.

Gemini CLI 0.61.0 (re-checked on 0.63.0).

Single prompt, on opening the folder; pre-selected: *1. Trust folder (q5-repo)*. Trusting the folder is also the decision that lets the declared server start; there is no second prompt.

```
Do you trust the files in this folder?
Trusting a folder allows Gemini CLI to load its local configurations,
including custom commands, hooks, MCP servers, agent skills, and settings.
These configurations could execute code on your behalf or change the
behavior of the CLI.
This folder contains:
  • MCP Servers (1):
   - q5-canary
> 1. Trust folder (q5-repo)
  2. Trust parent folder (lab)
  3. Don't trust
```

evidence/q5-run/20261009-194314/captures/gemini__untrusted__r2__prompt.txt
`fd6df21a88ebcc04bd0208ec4dd5fa922e746b202e11a0a405a523a4df880c75`
Variant: in gemini__untrusted__r1__prompt.txt of the same run

(cc5a5326ebcf3e89e8409332937835b3b6dd2c88e5a081e708e701842760c1a6) the block "This folder contains: … q5-canary" is absent; the rest is identical. On 0.63.0 the dialog text is identical. In some captures on both versions (e.g. the after-decision prompts of run 20261009-200610 on 0.61.0) it is preceded by the line "Skipping project agents due to untrusted folder. To enable, ensure that the project root is trusted." (evidence/q5-run/recheck-20261009/matrix-current-versions/captures/gemini__untrusted__r1__prompt.txt, 0da23b1959ddbfa724f4b10dca19d409f431ad22a35e54df4bc20c4b7006546b).

Codex CLI 0.157.1 (re-checked on 0.162.0).

Single prompt; pre-selected: *1. Trust and continue*. No MCP-specific prompt follows.

```
Folder access
/home/lab/q5-repo
Trust this folder? Codex can read, edit, and run files here, subject to
your permission settings. Folder settings can run code automatically, even
without a model request. Continue only if you trust these files. Your trust
decision will be saved.
> 1. Trust and continue
  2. Back to Agent Command Center
enter continue · esc back
```

evidence/q5-run/20261009-200610/captures/codex__untrusted__r1__prompt.txt 2f8041e0d08666c08ef2e252a8d6bc99e42769bb80aa278841b64b42df379e15
Variant: in later repetitions the second option reads `2. Quit` and the footer `enter continue · esc quit`, the rest being identical (evidence/q5-run/20261009-200610/captures/codex__untrusted__r2__prompt.txt, 11fcb1b0219cfa7de29885f31eebb3ce5eb09fc4ee10f24abae6b01ebfe5e4e8). Both variants occur on 0.162.0 (.../matrix-current-versions/captures/codex__untrusted__r1__prompt.txt, 5c9bf4511fb7c149f12b14a0d59d5a6591f496bb9c0cb1b5aece4e5369f61345, "Back to Agent Command Center"; codex__after-decision__r1__prompt.txt, e4822a363feead8fa065cf001361b7cca2db62e71a7002f1a1652a8407a4e9bd, "Quit"). The Codex cells of run 20261009-194314 after the first are invalid (see the run notes) and are not used.

Cursor CLI 2026.09.26.

For this client the appendix reports only what the author's published companion blog post (Costanzo 2026b, second post of the series, Sect. 03) states, quoted verbatim. First prompt, with `[a]` pre-selected:

```
Workspace Trust Required
Cursor Agent can execute code and access files in this directory.
This will also enable the MCP servers configured for this workspace.
Do you trust the contents of this directory?
/home/lab/q5-repo
> [a] Trust this workspace
  [w] Trust this workspace, but don't enable all MCP servers
  [q] Quit
```

(The post shows a warning sign, U+26A0, before the title.) On the second screen the post states: "Choosing [w] did not start it. The next session asked for approval of the workspace's servers, and again the pre-selected answer is the permissive one: approve all." The post reports that the automated cells, run on 2026.10.01 after a self-update, gave identical answers.

Qwen Code 0.24.6 (re-checked on 0.25.0).

No folder prompt; a single server prompt; pre-selected: *1. Approve this server*.

```
Untrusted MCP server in .qwen/settings.json
This workspace declares an MCP server. Approving lets Qwen Code start it and
run its tools.
Approval is bound to this exact configuration | if .qwen/settings.json
changes, you will be asked again.
q5-canary  node /home/lab/lab/canary/marker-server.mjs (stdio) [env:
CANARY_CLIENT, CANARY_SOURCE, CANARY_LOG]
> 1. Approve this server
  2. Approve all pending servers in this workspace
  3. Reject (esc)
```

evidence/q5-run/20261009-194314/captures/qwen__untrusted__r1__prompt.txt
`628b6bd514efc6e2eb89a41e5bbef3dc95e9be11afc47ca7c060427a31a25b73`
The same prompt reappeared after a change to `.qwen/settings.json` (`config-changed` cells, same hash). 0.25.0: identical dialog text (.../matrix-current-versions/captures/qwen__untrusted__r1__prompt.txt, `00a554c7b7c47b7ddecc842c0f78d61a696fb9a9cda35ce36762e82e33d53785`).

Goose 1.52.0.

No trust prompt and no server prompt: Goose does not read servers from the repository. The only question on the captured screen is a first-run telemetry question ("Share anonymous usage data to help improve goose?"), followed by `goose is ready`. evidence/q5-run/recheck-20261009/matrix-current-versions/captures/goose__open-in-repo__r1__screen.txt
`abd21b01c897da48d1685fb95afad5e7046db270e1336d696820cad16ee7020e`

VS Code 1.139.1 with GitHub Copilot (one run, interactive).

Opening the folder: Restricted Mode banner, no modal dialog ("Restricted Mode is intended for safe code browsing. Trust this folder to enable all features."). First prompt, on opening the chat; buttons in order *Manage*, *Cancel*, *Trust Folder & Continue*, the last highlighted as default:

> Do you trust the authors of the files in this folder?
> AI features are currently only supported in trusted workspaces.
> If you don't trust the authors of these files, we do not recommend continuing as the files may be malicious. See *our docs* to learn more.

Second prompt, in the chat, after the server had already been started without a question; primary button *Allow in this Session* (with a menu), then *Skip*:

> Run `canary_noop` – q5-canary (MCP Server)
> Records that it was called and returns ok. Does nothing else.
> *Note that MCP servers or malicious conversation content may attempt to misuse 'Code' through tools.*
> Records the call and returns ok.

evidence/gui-20261009/vscode-copilot-20261009/01-restricted-mode-chat-trust-dialog.png
`51dcf059a7450a2e78cb94088b39a63278510ab813edee1fecfeadb23a9169e8`
evidence/gui-20261009/vscode-copilot-20261009/03-chat-started-server-tool-approval.png
`230e1b2369e5025fbb4558ce713ea0e8d78e6b4f01e8a7bcc8548a2670cdeb7c`

Cursor IDE 3.22.7 (one run, interactive).

No trust prompt and no restricted mode on opening the folder; the project's server is listed as `q5-canary (q5-repo) · Disabled`. The only screen that can enable it is reached from the settings (Customize → MCPs), with the switch off; it does not show the command:

> Configure q5-canary · 1 source
> Source – Choose which source configures this MCP server.
> q5-repo · .cursor/mcp.json [switch: off]
> Environments – Local · Disconnected
> Reload Done

evidence/gui-20261009/cursor-ide-20261009/01-open-folder-no-trust-dialog.png
`c03732c1d00d4be79810b409832b049cd75dd2a25fa5f834f3690947f0150d0d`
evidence/gui-20261009/cursor-ide-20261009/05-configure-dialog-source-toggle-off.png
`98e0b56873654f8a1fd043754fcd41db9980a5e60a5f6ee7dc72e297fedeea0d`

B.2 Re-approval after a tool definition changes (RQ3)

Within the session, no client asked again because a definition had changed; after a restart (exploratory) only Gemini CLI asked again, which with its session-only approval cannot be told apart from an expired approval (see below). The questions below are the first-call approvals and the only change-related text any client showed in the primary matrix; the questions after the rename in the exploratory positive control (D52, Section 7) are not reproduced here and are in positive-control-20261028/ (Gemini CLI gemini__list_changed__name__r1/gemini__list_changed__r1__06-p2-approval.txt, Codex CLI codex__list_changed__name__r1/codex__list_changed__r1__06-p3-approval.txt), with hashes in the `manifest` key of that folder's `secret-gate.json`. Claude Code 2.1.300 and Qwen Code 0.25.1 (default auto modes), Goose 1.54.0 (`auto`) and Cursor IDE 3.22.7 (settings of our snapshot) asked nothing at any phase of the retained repetitions (the excluded Qwen Code attempt, D19, is described in Section 7). For Cursor CLI the screens of this experiment are not reproduced in this appendix; at the first call the harness chose *Allowlist MCP Tool* (Tab key), as recorded in the archived evidence. Paths below are relative to `tool-change/evidence/`; hashes are from its `SHA256SUMS`.

Codex CLI 0.162.1, first call.

Pre-selected: *1. Allow*; chosen: *3. Always allow*.

```
Calling q3-lab.q3_noop
  + Show details [collapsed: description not shown]
Field 1/1
Allow the q3-lab MCP server to run tool "q3_noop"?
> 1. Allow                   Run the tool and continue
  2. Allow for this session  Run the tool and remember this choice for this
session
  3. Always allow            Run the tool and remember this choice for
future tool calls
  4. Cancel                  Cancel this tool call
enter to submit | esc to cancel
```

primary-20261015/codex__none__description__r1/codex__none__r1__01-p1-approval.txt
f6d328b0ba8abc75444086f1036a22f331c0e563321b9077b2add2b1a1b01c84

Gemini CLI 0.64.0, first call and after restart.

Pre-selected: *1. Allow once*; chosen: *2. Allow tool for this session.* The same question returned after a restart (the chosen approval was session-only, so this cannot be told apart from an expired approval).

```
Action Required
? q3_noop (q3-lab MCP Server) q3_noop (q3-lab MCP Server)
MCP Server: q3-lab
Tool: q3_noop
MCP Tool Details:
(press Ctrl+O to expand MCP tool details) [collapsed]
Allow execution of MCP tool "q3_noop" from server "q3-lab"?
> 1. Allow once
  2. Allow tool for this session
  3. Allow all server tools for this session
  4. No, suggest changes (esc)
```

After the change with the notification, the only text shown (no question) was the line `(i) Tools updated for server: q3-lab` (glyph `U+2139` in the capture). First call: primary-20261015/gemini__none__description__r1/gemini__none__r1__01-p1-approval.txt
0fbc055e3fffc6991536f0a6c804125437ff8eb9998740f3c21a69b0275c915d
After restart:
primary-20261015/gemini__none__description__r1/gemini__none__r1__06-p3-approval.txt
9a66108c9b8020f52d9b34f3a797399d48c86a01ed4f8f376a71b4cb930dcdfd
Notice: primary-20261015/gemini__list_changed__description__r1/
gemini__list_changed__r1__04-p2-notice.txt
d3ea09643edefa2af7965c70472cbf33e23611f7945f6cae1c2f4a6909d52c23
The line above the box ("Call q3_noop: ...") is written by the model and differs between captures; it is omitted.

VS Code 1.139.1 with Copilot, first call (interactive; one run without the signal, two with the notification).

Primary button *Allow in this Session* (pre-selected), with a menu, then *Skip*; chosen: *Always Allow.*

> Run `q3_noop` – q3-lab (MCP Server)
>
> Lab tool, revision A. Returns the word ok and records the call in its own log. It has no other effect.
>
> *Note that MCP servers or malicious conversation content may attempt to misuse 'Code' through tools.*
>
> Records the call in its own log — no effect on workspace files.
>
> Menu, in order: Allow Once; Allow in this Workspace; Always Allow; Allow Tools from q3-lab in this Session; Allow Tools from q3-lab in this Workspace; Always Allow Tools from q3-lab.

gui-20261017/vscode-copilot__none__gui1/06-p1-approval-options.png
298211b60c05b3d1b942e54b0d9f6560a8a8f6a9953e7a6d32a09329eae8ca1e

Appendix D Deviations from the preregistration

Table D1 to Table D4 list every deviation from preregistration v2 (frozen 11 October 2026), in the order of the public log `DEVIATIONS.md`, whose repository history dates each entry (D1–D47 were pushed to the public repository when committed; D48–D56 were committed locally and first published with release v0.5.0 on 1 November 2026, so their dates rest on local commit times); D26, written on 17 October, was first committed on 22 October together with D27, before any Q4 session or run, and D50 was committed on 27 October (23:40 CET) although its header reads 28 October. All dates are 2026. The last column states which data existed when the entry was written, as the entry itself says or as its date and content show; the full text of every entry is in the log.

Table D1 Deviations from the preregistration, D1–D16. The log's opening statement that every entry "was written before any confirmatory data for RQ1, RQ3 or RQ5 was collected" is limited by a note added to the log on 25 October 2026 (D40): it holds for D1–D18; D19–D39 were written while the RQ3 and RQ5 campaigns were running or after them, each stating its date and which data existed; no RQ1 confirmatory data existed when D40–D43 were written. RQ: research question affected (All: every lab protocol; None: no research question).

ID	Date	Title	RQ	Written before/after which data
D1	11 Oct	Sampling frame for RQ1	RQ1	Before any confirmatory data
D2	11 Oct	Strength of the test of H1	RQ1	Before any confirmatory data
D3	11 Oct	Independence of the human rater R0	RQ1	Before any confirmatory data
D4	11 Oct	Model rater inputs and records	RQ1	Before any confirmatory data
D5	11 Oct	Size of the Q3 matrix	RQ3	Before any confirmatory data
D6	11 Oct	Detection metric for H5	RQ5	Before any confirmatory data
D7	11 Oct	Aggregation rules for H1 and H3	RQ1, RQ3	Before any confirmatory data
D8	11 Oct	Wording of the scope (systems controlled by the author)	All	Before any confirmatory data
D9	11 Oct	Summary statistic for RQ4	RQ4	Before any confirmatory data (exploratory RQ4 figure existed)
D10	11 Oct	Correction of the Q5 protocol statement on Codex	RQ2	Before any confirmatory data (exploratory RQ2 measurement existed)
D11	12 Oct	Target journal changed	None	Before any confirmatory data
D12	13 Oct	Q3 conformance with MCP 2026-07-28 and outcome coding	RQ3	Before any confirmatory data
D13	13 Oct	Holdout and reporting for H5	RQ5	Before any confirmatory data
D14	13 Oct	Pilot case C01, disclosure date, summaries, classifier	RQ1	Before any confirmatory data (after the pilot)
D15	13 Oct	RQ4 summary statistic, correcting D9	RQ4	Before any confirmatory data (exploratory RQ4 figure existed)
D16	15 Oct	Q3 delivery rule and cell procedure	RQ3	Before any confirmatory data (no RQ3 data of any kind)

Table D2 Deviations from the preregistration, D17–D32 (continued). Scope of the log's "before any confirmatory data" statement as in Table D1: D1–D18 only.

ID	Date	Title	RQ	Written before/after which data
D17	15 Oct	Per-tool census replaces the 9 October RQ4 reading	RQ4	Before any confirmatory data (after the 9 Oct RQ4 reading and after the per-tool RQ4 census and its aggregates were made; before any figure from the per-tool census was published; the earlier D9/D15 figures were already public)
D18	15 Oct	Q3 set-up runs, snapshot type, models for two clients	RQ3	Before any confirmatory data (after Q3 set-up runs, before any primary repetition)
D19	15 Oct	Client's own permission classifier unavailable; unexpected questions; one attempt excluded and re-run	RQ3	After the RQ3 primary matrix ended and after the failed attempt was seen, before outcomes were coded
D20	15 Oct	RQ3 coders	RQ3	After the RQ3 runs and rule-based outcomes, before any local-model answer was read
D21	15 Oct	Correction of D20: author coding restored	RQ3, RQ4	After the RQ3 runs and rule-based outcomes, before any local-model answer was read
D22	17 Oct	Additional independent coder from another model family (post hoc)	RQ3, RQ4	After RQ3 coding (author vs. local model) and the first RQ4 census reading
D23	17 Oct	What counts as an output-side defence	RQ4	After both RQ4 readings, before any coverage figure from the per-tool census was published
D24	17 Oct	Default client logs, new event runs, baseline and holdout	RQ5	After the RQ3 runs, before any Q4 (RQ5) run
D25	17 Oct	Seeds, set-up sessions and pipeline check before the Q4 campaign	RQ5	Before any Q4 run
D26	17 Oct	Logins for the Q4 snapshot; gate keeping secrets out of evidence	RQ5	Before any Q4 session or run
D27	22 Oct	Rule development, threshold, aggregation and freezing for H5	RQ5	Before any Q4 run
D28	22 Oct	Baseline driver fixes after the set-up sessions	RQ5	After exploratory set-up sessions, before any baseline session
D29	22 Oct	Cursor CLI without quota; Goose's ready pattern; longer set-up sessions	RQ5	After set-up round 2, before any event run
D30	22 Oct	End of Goose's turn; Gemini CLI's footer	RQ5	After set-up round 3, before the baseline
D31	22 Oct	Set-up sessions as rule-development material; window coverage; rule tooling	RQ5	After the set-up sessions and the first event runs (client logs not opened), before the baseline; no rule scored
D32	23 Oct	Quota stop without limit message; observer race; baseline restarted	RQ5	After the Q4 event runs and the first (aborted) baseline session

Table D3 Deviations from the preregistration, D33–D41 (continued).

ID	Date	Title	RQ	Written before/after which data
D33	23 Oct	Qwen Code's ready pattern; third start of the baseline	RQ5	After the event runs and part of the second baseline, before any holdout was scored
D34	23 Oct	Qwen Code's survey; prompt check before Enter; paid Gemini tier	RQ5	After the event runs and the second baseline attempt, before any holdout was scored
D35	23 Oct	Qwen Code's cursor; Claude Code notices; prepaid Gemini key; input checks	RQ5	After the event runs and earlier baseline attempts, before the third baseline
D36	23 Oct	Host-telemetry rules, start time of declared server, scoring tools	RQ5	While the third baseline ran, before any holdout was opened or rule scored
D37	23 Oct	A tip read as a quota stop; fourth start of the baseline	RQ5	After the third baseline stopped, before the fourth start
D38	24 Oct	Author's RQ4 adjudication helped by a proposing third reading	RQ4	After both RQ4 readings, during adjudication
D39	24 Oct	Open-weight cells, run after the RQ3 and RQ5 confirmatory results	RQ3	After RQ3 and RQ5 confirmatory results, before any open-weight cell
D40	25 Oct	Measurements announced but not done, and why	RQ2, RQ3, RQ5	After the RQ3 and RQ5 campaigns, before any RQ1 confirmatory data
D41	25 Oct	RQ1 frame and analysis rules, fixed before the frame is built	RQ1	Before the RQ1 query, frame, summaries or labels

Table D4 Deviations from the preregistration, D42–D56 (continued). D44–D56 postdate the log's 25 October note; their timing is taken from each entry's own text.

ID	Date	Title	RQ	Written before/after which data
D42	25 Oct	Who writes the summaries and what R0 reads	RQ1	Before any RQ1 confirmatory data
D43	25 Oct	Digest of rater R2 (Gemma 4)	RQ1	Before any RQ1 confirmatory run
D44	25 Oct	Stratified random sample of 120 cases from the frozen frame	RQ1	After the RQ1 query and frame, before any summary, label or model run
D45	26 Oct	How a mixed bundle is recognised	RQ1	After the summaries, before any R0 label or model run
D46	26 Oct	The author reads the summaries in Italian	RQ1	Before any R0 label or model run
D47	26 Oct	Guided questions on the R0 sheet	RQ1	Before any R0 label or model run
D48	27 Oct	Retry of transient transport and server failures for model raters	RQ1	After a server error ended the exploratory timing pilot of 27 Oct; before the confirmatory run
D49	27 Oct	Time limit of the confirmatory run extended during the run (logistics only)	RQ1	Decided during the confirmatory run; committed after it ended and after the analysis
D50	28 Oct	Four facts recorded after the fact (pilot examples, RQ3 control, RQ5 scope, analysis output)	RQ1, RQ3, RQ5	After all confirmatory data and analyses
D51	28 Oct	Exploratory: where the raters disagree; sheet and analysis for a second human rater	RQ1	After all confirmatory data and analyses; second-rater plan before any of its labels
D52	28 Oct	Exploratory: RQ3 positive control (renamed tool), one cell per client	RQ3	After all confirmatory data; committed before its cells
D53	31 Oct	RQ4 reading agreement reported on the published servers only	RQ4	After all results
D54	31 Oct	Two statements of D22 and D50 corrected (no figure changes)	RQ4, RQ5	After all results
D55	31 Oct	Post hoc RQ1 audit, RQ3 states, RQ4 partial detail, RQ5 coverage; reproduction without git history	all	After all results
D56	1 Nov	Post hoc RQ1 source audit and robust agreement; chronology of decisions; reproduction from the archive without git history	RQ1, all	After all results

Appendix E Protocol details moved from the paper

This section keeps, in the paper's earlier wording, protocol detail that the paper now gives in condensed form. Numbers of sections, tables and figures without a letter prefix refer to the paper.

E.1 Timing of the deviation entries (from Section 4, Preregistration)

Entries D1–D18 were written before any confirmatory data; D19–D39 were written while or after the RQ3 and RQ5 campaigns ran; D41–D48 were written before the RQ1 model runs (D48 on the day of the run, after a server error ended the exploratory timing pilot); D49 records an extension of the run's time limit decided during the run and committed after it ended; D50 records after the fact four facts the log had not stated, among them that the analysis code was extended after the results to report robustness and run-to-run instability (no figure changed); D51, written after all confirmatory analyses, adds the exploratory disagreement analysis of RQ1, materials for a second human rater and the reproduction script, including a script that regenerates one RQ5 agreement file previously produced without a committed script; D52, whose design was committed (locally; published with release v0.5.0) before its cells ran, adds the RQ3 positive control; D53 and D54, written on 31 October after all results, restrict the reported RQ4 reading agreement to the six published servers and correct two statements of D22 and D50 (no figure changes). D55 (31 October) and D56 (1 November) record the post hoc analyses described below. D40, written before any RQ1 confirmatory data, lists measurements announced but not done.

E.2 RQ1 frame, sample and runs (from Section 5)

Frame.

Deviation D44 replaced the preregistered population (the author's timeline of disclosures) with the D1 query of the GitHub Advisory Database and NVD: only one of the 330 frame cases comes from the timeline, so the result is an estimate for advisory-database disclosures. The frame follows deviations D1, D41, D44 and D45, each published before the step it governs; the screening rules were written after the query had run and before any candidate was read, and the final text of D44 was revised after the frame was built. A dated query of the GitHub Advisory Database and NVD (25 October 2026; keywords of D1) returned 695 candidate records. Screening against the inclusion criteria (a primary source; a tool-using agent, an MCP server or connector, or an agent SDK; disclosure in the window), a second reading of 43 uncertain records, the grouping of records into disclosures (one disclosure is one case, also across products), the exclusion of every pilot component and alias, and an eligibility check of every case against its primary source left 330 cases: 100 agent clients, 210 MCP servers or connectors, 20 SDKs. A case is dated by its first public advisory or researcher write-up; 142 cases were excluded because that date falls before the window. In counts (D44 point 7): 695 candidate records; 542 kept by screening and the second reading (510 included at once, 31 of the 43 uncertain, and 1 kept in doubt and flagged); 534 records

after removing pilot components and aliases, grouped into 471 disclosures, plus one record added by the Codex frame review (472 cases); 142 dated before the window; 330 cases in the frame; 120 sampled, all labelled by the author and all with complete model ratings. The frame, its inputs and the rules are public (Costanzo 2026a).

Sample.

A stratified random sample of 120 cases was drawn (D44): proportional allocation by product type (37, 76, 7), with a seed fixed by a public randomness beacon that did not exist when the frame was published — the SHA-256 of the frame hash and the drand mainnet round of the first 20:00 UTC at least one hour after the frame was pushed (round 6584246, 25 October 2026); the push time does not rest on the stored push event alone, since Internet Archive captures of the commit page and of the repository events page were made within one minute of the push (D44 point 4). The draw can be recomputed offline from the artifact, with or without its git history (Declarations). Nothing is replaced after the draw.

Runs.

The model raters ran on 27 October 2026 from 16:19 to 23:10 CET on a temporary copy of the lab GPU machine in another availability zone of the same region (capacity was unavailable in the original zone); the model digests were checked against the frozen roster before the run, and the run manifest records them with the hashes of the cases, criteria and R0 file. Transient server or transport errors are retried with the identical request (D48); none occurred during the confirmatory run. The run took longer than the timing pilot predicted, and its time limit was extended during the run with the author's approval (D49); this changed only how long the machine stayed on.

E.3 RQ1 class-3 audit: where the two coders differ (from Section 5, Interpretation)

Of the 58 class-3 labels that go beyond the literal class-3 wording, the AI coder and the blind check by a model of another provider agree on all fields for 47. For 4 both find that the source frames the flaw as an access or permission bypass (7 by either), for 4 the first finds no property stated, and for 3 of the 10 agent clients among them both see the class-1 wording as a competing reading (5 by either); disagreements are recorded, not resolved by relabelling.

E.4 RQ2 automated runs (from Section 6)

A test repository declares one harmless canary server in the six project configuration files; a server counts as started when the canary writes its start record. A manual pass covered all clients but Cursor IDE on 28 September. On 9 October 2026 a runner with fixed keystrokes drove the six terminal clients in 75 valid automated runs; a cell is one client in one condition (untrusted folder, after the trust decision, reopening a trusted folder, or a client-specific variant), and a run is one repetition of a cell. The first set has 46 runs: a full matrix and, after a snapshot revert, a targeted re-run of the Codex CLI cells and of the Gemini CLI cell after the trust decision; the Codex CLI cells of

Table E1 Table 11 filled in for Codex CLI from this study's records (applicability to our own data only).

#	Codex CLI
1	0.157.1 and 0.162.0 (RQ2), 0.162.1 (RQ3, RQ5); default model (RQ3)
2	interactive runner with fixed keystrokes; non-interactive mode stopped at an authentication or trusted-directory check (RQ2)
3	first question "trust folder", warns that settings run code, pre-selects "Trust and continue"; accepting it started the server (3/3); full-matrix cells invalid because a background-server screen replaced the trust question; re-run after a snapshot revert
4	first call: "1. Allow" pre-selected, "3. Always allow" chosen; no question in the session (B never fetched) or after reopening with B (10/10)
5	one no-op stdio server, earlier protocol revision than 2026-07-28; definitions A and B in the server log
6	notification delivered (server log); no new tool list fetched (stale 5/5)
7	not applicable (server-side item)
8	default logs: server start 2/2, announced change 2/2, silent change no rule (no stored tool definition in the inspected sources)
9	not recorded for this client (the synced-account note concerns Claude Code)
10	RQ2: no restore within a set; RQ3: five repetitions, each from a clean snapshot; RQ5: two event runs per type

the full matrix are invalid and excluded, because a background-server screen of Codex replaced the trust question. Of these 46 runs, 38 used the late-September versions; the 8 Cursor CLI runs did not, because Cursor CLI updated itself from 2026.09.26 to 2026.10.01 during its first run. A second set of 29 runs used the releases of 9 October, with one repetition per cell except Gemini CLI. The two graphical clients were operated interactively outside the runner (keystrokes sent by the AI assistant, Section 4), once each in the configuration reported (VS Code with Copilot signed in, on 9 October; in the 28 September pass, without Copilot, VS Code started no project server on trust). Repetitions are not independent: the virtual machine was not restored between runs within a set, and runs that reopen a repository keep the decisions stored in earlier runs.

E.5 The reporting checklist filled in for one client (from Section 10)

Table E1 fills in the checklist of Table 11 for one client from this study's own records; it shows that the items can be filled from our data, not that the checklist has been validated externally.

References

Costanzo P (2026a) Outside the prompt — reproducible lab harness. https://doi.org/10.5281/zenodo.23861225, https://doi.org/10.5281/zenodo.23861225, version v0.5.0; concept DOI 10.5281/zenodo.23300292

Costanzo P (2026b) Trusting a repo now means trusting its MCP servers. https://paolocostanzo.github.io/trusting-a-repo-means-trusting-its-mcp-servers/, Blog post, second of the series "Outside the Prompt", 13 October 2026. Accessed 31 October 2026